

RDP Brute-Force Attack

Compromise & Breach Detection with Splunk SIEM

A Full Attack-and-Detect Kill-Chain — Home-Lab Portfolio Project

Sagar Bidari

CompTIA Security+ (SY0-701) | SOC Analyst Candidate

Melbourne, Australia

Report Date: 2 October 2026

Executive Summary

This project runs a complete attack-and-detect kill chain against the Remote Desktop Protocol (RDP) in a self-built home lab, demonstrating the end-to-end workflow of a SOC analyst: launch the attack, collect the telemetry, and build the detection. An attacker host (Kali Linux) ran a **THC-Hydra** dictionary brute-force against a Windows target's RDP service, and every stage was observed in **Splunk Enterprise** through Windows logon events — the failures as **Event ID 4625** and the successful breach as **Event ID 4624**.

Two outcomes were produced, which together tell a complete story. A hardened account resisted the attack and was locked out by policy; a deliberately weak, isolated lab account was compromised in seconds. Both the failed campaign and the successful breach were detected and characterised in the SIEM.

At a glance	
Attacker source	192.168.100.134 (Kali Linux)
Target	Windows 'homelabvm' — 192.168.100.135, RDP 3389
Technique	Dictionary brute-force (MITRE T1110.001) → Valid Accounts (T1078)
Target A — 'cyber'	RESISTED — 0 cracked, 24 failures, account locked out
Target B — 'labvictim'	COMPROMISED — cracked on 5th guess (Password1)
Detection result	DETECTED — 24 x 4625 failures + 3 x 4624 breach logons, attacker IP attributed

1. Objective

This project demonstrates a complete **attack-and-detect kill chain** against RDP in a controlled home lab: reconnaissance, a dictionary brute-force attack from Kali Linux, a successful account compromise, and interactive RDP access — then the defensive side, detecting and characterising the whole chain in **Splunk Enterprise**. Windows **Event ID 4625 (failed logon)** and **Event ID 4624 (successful logon)** are the primary detection signals.

The goal is to show end-to-end capability expected of an entry-level SOC analyst: generating malicious authentication activity, forwarding Windows Security telemetry into a SIEM, writing SPL detections that isolate the attack and identify its source, and — critically — correlating failures with a success to recognise an **actual compromise**.

Scope and ethics: all activity was performed on isolated virtual machines owned and operated by the author, on a private host-only / NAT network. The compromised account ('labvictim') is a dedicated, disposable local account created solely for this exercise — no real account was targeted. No third-party systems or networks were involved.

2. Lab Environment

The lab consists of two virtual machines on a VMware private network. Kali Linux serves as both the attacker and the SIEM host; the Windows VM is the victim endpoint running a Universal Forwarder that ships its Security event log to Splunk.

Role	System	IP Address	Key Software / Config
Attacker	Kali Linux	192.168.100.134	THC-Hydra 9.7, FreeRDP (xfreerdp), Nmap
SIEM / Indexer	Kali Linux (same host)	192.168.100.134	Splunk Enterprise 10.4.2, receiving :9997, Web :8000
Target / Victim	Windows (homelabvm)	192.168.100.135	RDP :3389, Splunk Universal Forwarder
Network	VMware private	192.168.100.0/24	Isolated lab segment

Data pipeline: the Windows Universal Forwarder monitors *WinEventLog://Security* and forwards events to the Splunk indexer on TCP 9997, landing in *index=main* with sourcetype *WinEventLog:Security*. Logon auditing (success and failure) was enabled so that both failed and successful logons are captured.

```
# On the Windows target – enable logon auditing (success + failure)
auditpol /set /subcategory:"Logon" /success:enable /failure:enable

# Universal Forwarder input (etc/system/local/inputs.conf)
[WinEventLog://Security]
disabled = 0
index = main
```

3. Attack Methodology

3.1 Phase 1 — Reconnaissance

The target was fingerprinted with Nmap to confirm RDP (TCP 3389) was open — an attacker's first move: validate the attack surface before expending effort.

```
sudo nmap -sV -p 3389 192.168.100.135
```

Result: port 3389/tcp **open** running *ms-wbt-server* (Microsoft Remote Desktop) — a valid brute-force target.

3.2 Phase 2 — Dictionary Brute-Force (Hydra)

A ~20-password dictionary of common and lab-themed passwords was built on Kali, then THC-Hydra was run against the target's RDP service. A single thread (-t 1) was used for stability (see 3.3).

```
# Wordlist (excerpt) — ~/password.txt
password / 123456 / admin / letmein / Password1 / qwerty
welcome / changeme / cyber123 / P@ssw0rd / monash ...

# Launch the RDP dictionary attack
hydra -l <user> -P ~/password.txt -V -t 1 rdp://192.168.100.135
```

3.3 Finding — FreeRDP Module Instability

Hydra's RDP module (FreeRDP-based) proved unstable against modern Windows, returning *"connection failed to establish"* and *"all children were disabled due to too many connection errors."* Disabling Network Level Authentication (NLA) on the target and running single-threaded (-t 1) were needed to reach the logon stage. This is itself a finding: **NLA is an effective first-line control** that frustrated the tool before authentication. The module is also unreliable at *confirming* a success — a point that shaped the methodology in Section 4.

4. Attacker-Side Results — Two Accounts, Two Outcomes

4.1 Target A — 'cyber' (resisted)

The initial target, account *cyber*, withstood the attack. Hydra cycled the full wordlist and found **0 valid passwords** — the password was not guessable from a common-password list. Two defensive controls were observed working:

- **Account lockout fired.** The repeated failures tripped the Windows account-lockout policy; the account showed a status of *Locked*, halting further attempts — a textbook brute-force mitigation operating as intended.
- **The account was not locally resettable.** It is backed by a Microsoft/online identity (a local password reset returned *System error 8646*), meaning it was not a soft target.

This produced **24 failed-logon (4625) events** — the detectable brute-force campaign analysed in Section 5.

4.2 Target B — 'labvictim' (compromised)

To demonstrate what a successful compromise looks like in the SIEM, a dedicated, isolated local account *labvictim* was created with a deliberately weak password (*Password1*) present in the wordlist, and added to the Remote Desktop Users group. This is deliberate lab hygiene — a disposable victim rather than a real account. Hydra cracked it almost immediately:

```
root@kali: /home/kali
Session Actions Edit View Help

(root@kali) - [/home/kali]
# hydra -l labvictim -P ~/password.txt -V -t 1 rdp://192.168.100.135
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-01 22:01:48
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 1 task per 1 server, overall 1 task, 20 login tries (l:1/p:20), ~20 tries per task
[DATA] attacking rdp://192.168.100.135:3389/
[ATTEMPT] target 192.168.100.135 - login "labvictim" - pass "password" - 1 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.100.135 - login "labvictim" - pass "123456" - 2 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.100.135 - login "labvictim" - pass "admin" - 3 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.100.135 - login "labvictim" - pass "letmein" - 4 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.100.135 - login "labvictim" - pass "Password1" - 5 of 20 [child 0] (0/0)
[3389]rdp host: 192.168.100.135 login: labvictim password: Password1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-01 22:02:00
```

Figure 4 — Hydra success: account 'labvictim' cracked on the 5th guess (password: Password1). "1 valid password found."

The key lesson: a weak password falls in seconds. Only four failed guesses preceded the success — the difference between Target A and Target B was entirely password strength and lockout policy, not the attacker's effort.

5. Detecting the Brute-Force (Event ID 4625)

With telemetry in *index=main*, four SPL searches move from raw events to an alert — baseline, isolate, fingerprint, burst. All figures are live screenshots from the author's Splunk instance.

5.1 Search 1 — Baseline: all failed logons

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625
```

24 failed-logon events (Event ID 4625) from the target — confirming the pipeline and the attack volume.

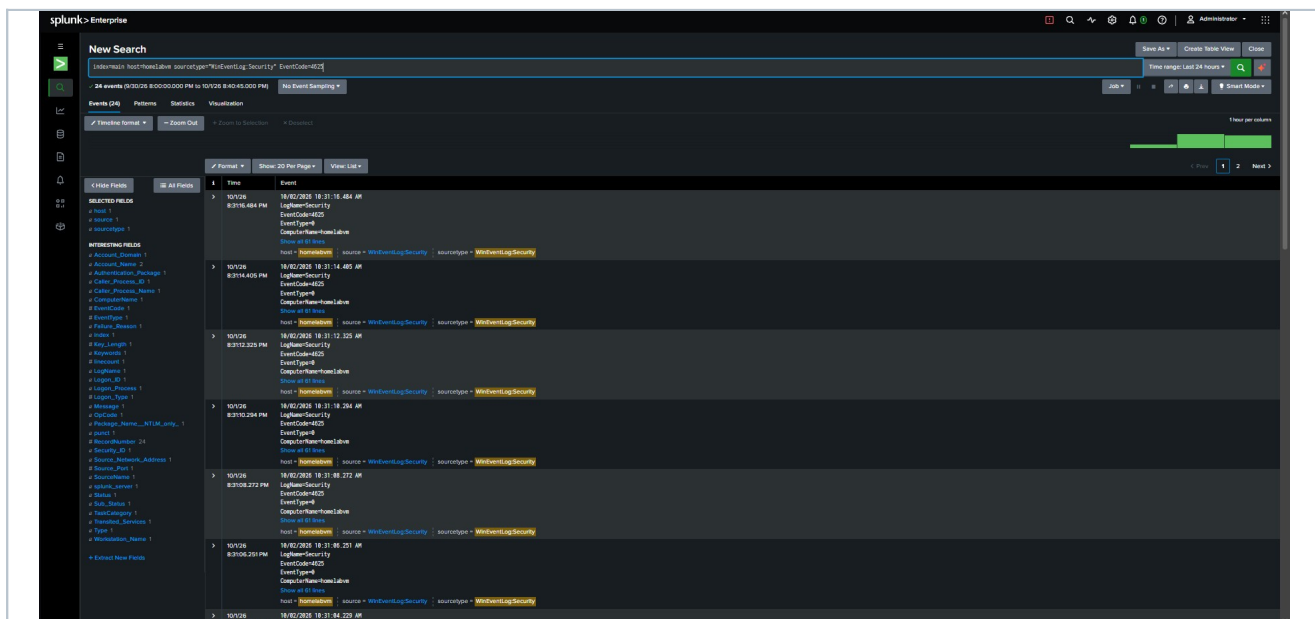


Figure 1 — Baseline: 24 Event ID 4625 (failed logon) events from host homelabvm in *index=main*.

5.2 Search 2 — Isolate the RDP / network brute-force attempts

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625 (Logon_Type=3
OR Logon_Type=10)
| table _time, Account_Name, Logon_Type, Source_Network_Address, Failure_Reason
```

Every failure is Logon Type 3 from 192.168.100.134, reason "Unknown user name or bad password", with a ~2-second cadence — the fingerprint of an automated tool, not a human mistyping.

The screenshot shows a Splunk search interface with the following search query: `index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625 (Logon_Type=3 OR Logon_Type=18) | table _time, Account_Name, Logon_Type, Source_Network_Address, Failure_Reason`. The results table displays 24 events, all with the same source network address (192.168.100.134) and failure reason ("Unknown user name or bad password").

_time	Account_Name	Logon_Type	Source_Network_Address	Failure_Reason
2020-10-01 19:34:40.487	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:34:40.487	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:34:44.448	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:34:42.427	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:34:40.487	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:34:38.385	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:34:36.366	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:34:34.345	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:36:21.888	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:36:21.863	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:36:21.863	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:35:32.282	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:35:32.282	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:35:32.282	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 19:35:32.282	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 20:31:16.484	cyber	3	192.168.100.134	Unknown user name or bad password.
2020-10-01 20:31:14.485	cyber	3	192.168.100.134	Unknown user name or bad password.

Figure 2 — RDP attempts isolated: all failures are Logon Type 3 from 192.168.100.134, ~2 seconds apart.

5.3 Search 3 — Attacker fingerprint

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625
| stats count AS failed_attempts, min(_time) AS first_seen, max(_time) AS last_seen
  by Account_Name, Source_Network_Address
| sort - failed_attempts
```

One-line verdict: 24 failures from a single source against one account, bounded by first/last-seen — the signature a SOC escalates.

The screenshot shows a Splunk search interface with the following search query: `index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625 | stats count AS failed_attempts, min(_time) AS first_seen, max(_time) AS last_seen by Account_Name, Source_Network_Address | sort - failed_attempts`. The results table shows two rows, one for each account and source address, both with 24 failed attempts.

Account_Name	Source_Network_Address	failed_attempts	first_seen	last_seen
-	192.168.100.134	24	179809332.282	1798091876.484
cyber	192.168.100.134	24	179809332.282	1798091876.484

Figure 3 — Attacker fingerprint: 24 failed attempts from 192.168.100.134, first_seen / last_seen bounding the window.

5.4 Search 4 — Burst detection (alert logic)

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4625
| bucket _time span=1m
| stats count AS attempts_per_min by _time, Source_Network_Address
| where attempts_per_min >= 5
```

Buckets failures into one-minute windows per source and fires above five per minute — the detection as an alert. The attack's cadence breaches this cleanly.

6. Detecting the Compromise (Event ID 4624)

A failed campaign is routine; a *successful* logon that follows a burst of failures is an incident. Using the cracked credential, an interactive RDP session was established from the attacker host — generating Windows **Event ID 4624** (successful logon).

6.1 Interactive RDP access confirmed

The cracked credential was used to open a live RDP session to the target from Kali (xfreerdp), confirming the account was fully compromised and remotely usable:

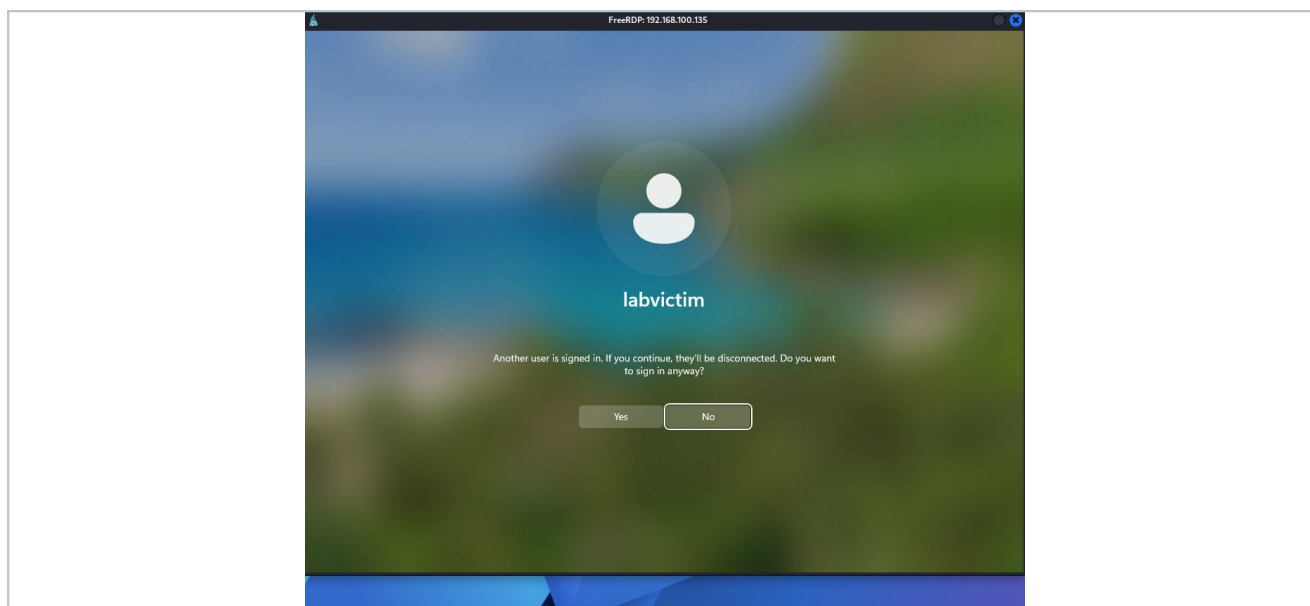


Figure 5 — Interactive RDP session established to 192.168.100.135 as 'labvictim' using the cracked password.

6.2 The breach in Splunk — successful logons

```
index=main host=homelabvm sourcetype="WinEventLog:Security" EventCode=4624  
Source_Network_Address=192.168.100.134
```

Three successful logons (Event ID 4624) were recorded **from the attacker's IP, 192.168.100.134** — hard evidence that the brute-force translated into real access.

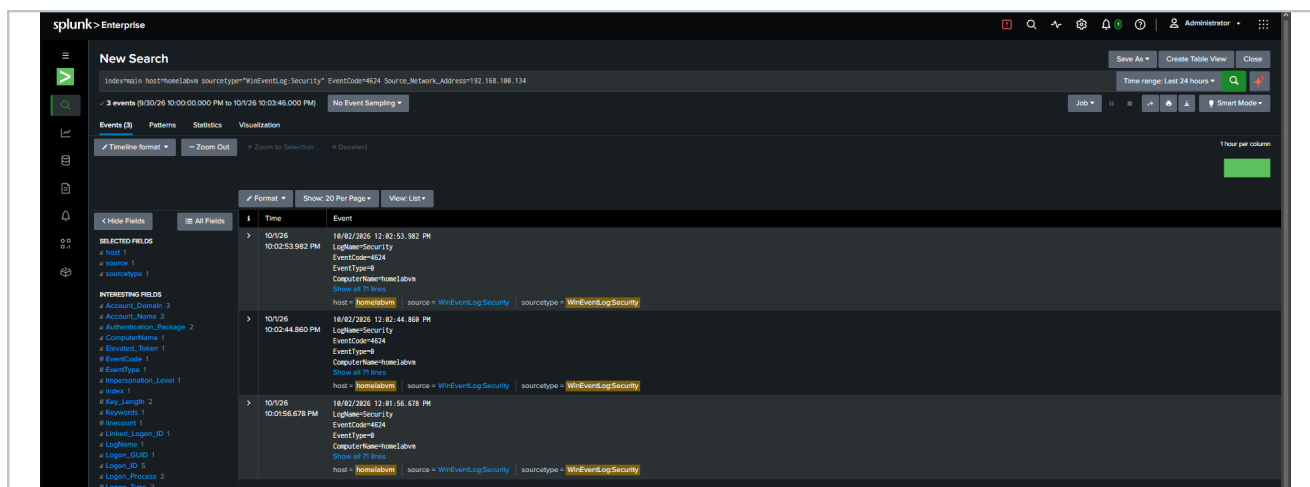


Figure 6 — Breach confirmed: Event ID 4624 successful logons on homelabvm, sourced from the attacker 192.168.100.134.

6.3 Correlation — brute-force that succeeded

The highest-value detection correlates the two signals: a source that produced many failures and then a success is a confirmed compromise, not noise.

```
index=main host=homelabvm sourcetype="WinEventLog:Security" (EventCode=4625 OR
EventCode=4624)
| stats count(eval(EventCode=4625)) AS failures, count(eval(EventCode=4624)) AS successes,
  values(Account_Name) AS accounts by Source_Network_Address
| where failures >= 5 AND successes >= 1
```

This returns a single, unambiguous row: **source 192.168.100.134 produced many failed logons and then succeeded** — the exact pattern that should page an analyst. In production this runs as a scheduled alert (Section 7).

7. Operationalising the Detection (Detection-as-Code)

Detections should be reusable and portable, not one-off searches. The logic is captured as a scheduled Splunk alert and a vendor-neutral Sigma rule.

7.1 Splunk scheduled alert — savedsearches.conf

```
[RDP Brute-Force Succeeded - 4625 burst then 4624]
search = index=main sourcetype="WinEventLog:Security" (EventCode=4625 OR EventCode=4624) \
  | stats count(eval(EventCode=4625)) AS failures, \
    count(eval(EventCode=4624)) AS successes by Source_Network_Address, Account_Name \
  | where failures >= 5 AND successes >= 1
dispatch.earliest_time = -10m
cron_schedule = */5 * * * *
enableSched = 1
alert.severity = 5
action.email = 1
```

7.2 Portable detection — Sigma rule

```
title: RDP Brute-Force - Multiple Failed Logons from Single Source
status: experimental
description: Burst of Windows 4625 network-logon failures from one source IP (RDP brute-force).
logsource:
  product: windows
  service: security
detection:
  selection:
    EventID: 4625
    LogonType: [3, 10]
  timeframe: 1m
  condition: selection | count() by IpAddress >= 5
level: high
tags:
  - attack.credential_access
  - attack.t1110.001
```

7.3 False positives & tuning

- **Stale cached credentials** (mapped drives, scheduled tasks) can mimic the pattern — exclude known service accounts/IPs via a lookup.
- **Baseline** normal 4625 volume per host and set the threshold above it.
- **Restrict Logon Type** to 3/10 to exclude noisy interactive/service failures.

- **Escalate on the 4625→4624 correlation** — that sequence (Section 6.3) is the true compromise signal and warrants immediate response.

8. MITRE ATT&CK Mapping

Tactic	Technique	ID	Where it appears
Reconnaissance	Network Service Discovery	T1046	Nmap scan of RDP (3389)
Credential Access	Brute Force: Password Guessing	T1110.001	Hydra dictionary attack
Initial Access / Persistence	Valid Accounts	T1078	Login with cracked 'labvictim' credentials
Lateral Movement	Remote Services: RDP	T1021.001	Interactive RDP session over 3389

9. Findings Summary

#	Finding	Evidence
1	RDP (3389) exposed and reachable	Nmap: 3389/tcp open, ms-wbt-server
2	Hardened account 'cyber' resisted the brute-force	0 valid passwords; account locked out by policy
3	Weak account 'labvictim' compromised in 5 guesses	Hydra: password Password1 found (Fig 4)
4	Interactive RDP access achieved with cracked creds	Live xfreerdp session to target (Fig 5)
5	Brute-force fully detected via Event ID 4625	24 x 4625 events; source & cadence identified (Figs 1-3)
6	Breach confirmed via Event ID 4624	3 x 4624 success from 192.168.100.134 (Fig 6)
7	Compromise detectable by 4625→4624 correlation	Correlation search returns the attacker source
8	Account lockout proven as an effective control	Target A locked out, halting the attack

10. Skills Demonstrated

Competency	Demonstrated by
SIEM operation	Splunk indexer + Universal Forwarder; index/sourcetype routing; receiver on 9997
Log source onboarding	Windows Security event forwarding; auditpol audit-policy configuration
Threat detection (SPL)	Baseline → isolate → fingerprint → burst → 4625/4624 compromise correlation
Detection engineering	savedsearches.conf alert + Sigma rule + false-positive tuning
Offensive testing	Nmap recon; Hydra RDP brute-force; FreeRDP interactive access
Frameworks	MITRE ATT&CK (T1046, T1110.001, T1078, T1021.001)
Troubleshooting	Diagnosed forwarder/NLA/FreeRDP, MSA vs local account (err 8646), lockout
Analysis & reporting	Evidence-based kill-chain writeup with annotated screenshots

11. Conclusion

This project delivered a full RDP attack-and-detect kill chain. Reconnaissance confirmed an exposed RDP service; a Hydra dictionary attack was launched against two accounts with opposite results — a hardened, Microsoft-backed account resisted and was locked out by policy, while a deliberately weak, isolated lab account was cracked in five guesses and used to open a live RDP session. On the defensive side, the Windows Security log captured the entire chain: 24 failed logons (Event ID 4625) characterising the brute-force, and three successful logons (Event ID 4624) from the attacker's IP confirming the breach. A progression of SPL searches turned this telemetry into a precise detection, culminating in a 4625→4624 correlation that distinguishes a failed campaign from an actual compromise, packaged as reusable detection-as-code.

The key analyst takeaway: the difference between a blocked attack and a breach was password strength and account lockout — nothing else. The SIEM's job is to catch both: to flag the noisy failures, and above all to recognise the quiet success that follows them.

12. Defensive Recommendations

- **Don't expose RDP directly.** Put it behind a VPN or RD Gateway; never publish 3389 to untrusted networks.
- **Enforce NLA, account lockout, strong passwords and MFA.** Target A survived precisely because of these; Target B fell for lack of them.
- **Alert on the 4625→4624 correlation.** Deploy the Section 7 scheduled search so a successful logon after a failure burst pages an analyst immediately.
- **Restrict source IPs.** Where RDP is required, limit inbound 3389 to known management ranges.
- **Avoid weak, reused passwords.** "Password1" and similar fall in seconds to a common wordlist.

Appendix A — Reference Data

Event ID 4625: "An account failed to log on" — the brute-force signal.

Event ID 4624: "An account was successfully logged on" — the breach signal.

Logon Type 3 / 10: Network / RemoteInteractive (RDP) logon.

Splunk index / sourcetype: index=main, sourcetype=WinEventLog:Security.

Note on timestamps: times are as indexed by Splunk; the Windows source and SIEM host are in different time zones, so raw event-log local times differ from Splunk's indexed _time by the host offset. All analysis is anchored on Splunk's indexed time.